

시큐어코딩



SW개발보안 국내기준

01 소프트웨어 개발보안 가이드

02 클라우드서비스(SaaS) 보안인증 가이드



학습 목표

- ✓ 소프트웨어 개발보안을 위한 국내 기준으로 활용되는 소프트웨어 개발보안 가이드에서 설명하고 있는 설계단계, 구현단계 보안 활동에 대해 학습한다.
- ✓ SaaS 애플리케이션을 대상으로 실시되는 클라우드 보안인증 통제항목의 기술적보호 조치 등에서 설명하는 개발보안을 이해한다.

학습 내용

1. 소프트웨어 개발보안 가이드
2. 클라우드서비스(SaaS) 보안인증 가이드



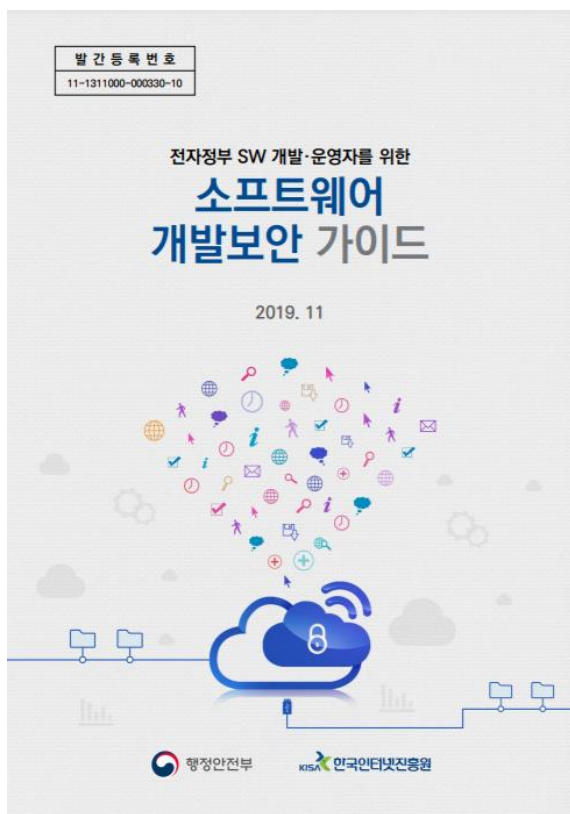
SW개발보안 국내기준

01 소프트웨어 개발보안 가이드

02 클라우드서비스(SaaS) 보안인증 가이드

행정안전부 SW개발보안 가이드

행정기관 등이 안전한 소프트웨어를 개발하여 각종 사이버위협으로부터 예방·대응하기 위해 SW 개발단계 부터 SW개발 보안을 적용하기 위한 기준으로 제공



활용

개발보안

행정·공공기관 정보시스템 개발자 및 유지보수자, 담당공무원



진단

진단원 및 감리원, 사업자 자체 SW보안약점 잔존여부 진단 등

행정기관 및 공공기관 정보시스템 구축·운영 지침 [시행 2021. 1. 19.]
[행정안전부고시 제2021-3호, 2021. 1. 19., 일부개정]

행정안전부 SW개발보안 가이드

행정기관등이 정보화사업을 추진할 때, SW보안약점이 없도록 SW를 개발 또는 변경
행정기관 및 공공기관 정보시스템 구축·운영 지침 [시행 2021. 1. 19.]
[행정안전부고시 제2021-3호, 2021. 1. 19., 일부개정]

대상

정보 시스템 감리 대상 정보화 사업 [전자정부법 시행령 제 17조 제 1항]
※ 감리대상이 아닌 정보화사업도 SW개발보안 적용 가능

범위

설계단계 산출물 및 소스코드 전체
(유지보수의 경우, 유지보수로 인해 변경된 설계단계 산출물 및 소스코드 전체)
※ 상용 SW 제외

행정안전부 SW개발보안 가이드

◆ 필수 진단 항목 : 행정기관 및 공공기관 및 공공기관 정보시스템 구축 · 운영 지침 '별표3'

※ 설계단계 보안설계 기준 : 20개 항목

※ 구현단계 보안약점 제거 기준 : 49개 항목

◆ 진단도구(SW 보안약점 진단도구)

※ 개발과정에서 소스코드 상의 SW 보안약점을 찾기 위하여 사용하는 도구

※ 감리법인이 진단도구를 사용할 경우에는 과학기술정보통신부장관이 고시한 정보보호 시스템 평가 인증 지침에 따라 **국가보안기술연구소장이 인증한 진단도구를 사용**

◆ 진단원(SW 보안약점 진단원)

※ SW 보안약점이 남아있는지 진단하여 조치방안을 수립하고 조치결과 확인 등의 활동을 수행하는 자

※ 감리법인은 행정안전부장관이 고시한 "정보시스템 감리기준" 제5조 제3항에 따라 진단원을 우선적으로 배치

※ 행정기관은 감리대상이 아닌 정보화사업에 SW개발보안을 적용할 경우에는, 사업자로 하여금 보안약점을 진단 · 제거토록 하고 그 결과를 확인

행정안전부 SW개발보안 가이드

[별표3] 소프트웨어 보안약점 기준(제 52조 관련) 설계단계 보안요구항목

구분(4)	주요 내용	설계단계 보안 요구항목	개수(20)
 입력데이터 검증 및 표현	사용자, 프로그램 입력 데이터에 대한 유효성 검증체계를 갖추고 실패 시 처리방안 제시	1. DBMS 조회 및 결과 검증 2. XML 조회 및 결과 검증 3. 디렉토리 서비스 조회 및 결과 검증 4. 시스템 자원 접근 및 명령어 수행 입력값 검증 5. 웹 서비스 요청 및 결과 검증 6. 웹 기반 중요 기능 수행요청 유효성 검증 7. HTTP프로토콜 유효성 검증 8. 허용된 범위내 메모리 접근 9. 보안기능 동작에 사용되는 입력값 검증 10. 업로드 다운로드 파일 검증	10개
 보안기능	인증, 접근제어, 권한 관리, 비밀번호 등의 정책이 적절하게 반영될 수 있도록 설계	1. 인증 대상 및 방식 2. 인증 수행 제한 3. 비밀번호 관리 4. 중요자원 접근통제 5. 암호키 관리 6. 암호연산 7. 중요정보저장 8. 중요정보 전송	8개
 에러처리	오류메시지에 중요정보가 포함되어 출력되지 않도록 안전한 처리방안 설계	1. 예외처리	1개
 세션통제	다른 세션간 데이터 공유 금지 등 세션을 안전하게 관리할 수 있는 방안 제시	1. 세션 통제	1개

입력값 검증

중요정보 처리

인증

인가

암호화

에러처리

세션 통제

로깅

행정안전부 개발보안 가이드

[별표3] 소프트웨어 보안약점 기준(제 52조 관련) 구현단계 49개 보안약점 제거 기준

입력데이터 검증 및 표현	SQL 삽입	코드삽입	경로 조작 및 자원 삽입	크로스사이트 스크립트	운영체제 명령어 삽입	위험한 형식 파일 업로드
	신뢰되지 않은 URL 주소로 자동 접속 연결	부적절한 XML외부 객체 참조	XML삽입	LDAP 삽입	크로스사이트 요청 위조	서버사이드 요청위조
	HTTP 응답분할	정수형 오버플로우	보안기능 결정에 사용되는 부적절한 입력값	메모리 버퍼 오버플로우	포맷 스트링 삽입	
보안기능	적절한 인증 없는 중요기능 허용	부적절한 인가	중요한 자원에 대한 잘못된 권한 설정	취약한 암호화 알고리즘 사용	암호화되지 않은 중요정보	하드코드 된 중요정보
	충분하지 않은 키 길이 사용	적절하지 않은 난수값 사용	취약한 비밀번호 허용	부적절한 전자서명 확인	부적절한 인증서 유효성 점검	사용자 하드디스크에 저장되는 쿠키를 통한 정보 노출
	주석문 안에 포함된 시스템 주요정보	솔트 없이 일방향 해쉬 함수 사용	무결성 검사 없는 코드 다운로드	반복된 인증시도 제한 기능 부재		
시간 및 상태	검사시점과 사용시점	종료되지 않은 반복문 재귀함수				
에러처리	오류메시지 정보 노출	오류 상황 대응 부재	부적절한 예외 처리			
코드오류	Null Pointer 역참조	부적절한 자원해제	해제된 자원 사용	초기화되지 않은 변수 사용	신뢰할 수 없는 데이터의 역직렬화	
캡슐화	잘못된 세션에 의한 데이터 정보노출	제거되지 않고 남은 디버그 코드	Public 메소드 부터 반환된 Private 배열	Private 배열에 Public 데이터 할당		
API 오용	DNS Lookup에 의존한 보안 결정	취약한 API 사용				

입력 값 검증
보안기능
에러처리
세션통제

국내 SW개발보안 제도(과학기술정보통신부)

2020년 SW산업진흥법이 개정되어 민간 기업 SW개발시 SW개발보안을 적용하도록 함

SW개발보안(제29조)

"소프트웨어개발보안"이란 소프트웨어를 개발하거나 변경할 때 소프트웨어의 보안 취약점을 최소화하기 위한 일련의 보안활동

제29조(소프트웨어개발보안진흥)과학기술정보통신부장관은 소프트웨어개발보안분야를 진흥하기 위하여 다음 각 호의 사업을 추진할 수 있다.

1. 소프트웨어개발보안기술 연구, 인력양성 등 기반 조성
2. 「중소기업기본법」 제2조에 따른 중소기업인 소프트웨어사업자의 소프트웨어개발보안 활성화를 위한 지원
3. 그 밖에 소프트웨어개발보안을 활성화하기 위하여 대통령령으로 정하는 사업

SW안전(제30조, 31조)

“소프트웨어안전”이란 외부로부터의 침해행위가 없는 상태에서 소프트웨어의 내부적인 오작동 및 안전기능(사전 위험분석 등을 통하여 위험발생을 방지하는 기능을 말한다)미비 등으로 발생할 수 있는 사고로부터 사람의 생명이나 신체에 대한 위험에 충분한 대비가 되어 있는 상태를 말한다.

제30조(소프트웨어안전 확보) ① 정부는 소프트웨어안전 확보를 위한 시책을 마련할 수 있다.

② 과학기술정보통신부장관은 다음 각 호의 사항을 포함하는 소프트웨어안전 확보를 위한 지침을 정하여 고시하여야 한다.

1. 소프트웨어안전 관련 위험 분석
2. 소프트웨어안전 확보를 위한 설계 및 구현 방법
3. 소프트웨어안전 검증 방법
4. 운영 단계의 소프트웨어안전 확보 방안
5. 그 밖에 소프트웨어안전 확보에 필요하다고 인정되는 사항

③ 중앙행정기관의 장은 소관 분야의 소프트웨어안전에 관한 기술기준을 수립하는 경우 제2항에 따른 지침 또는 국제표준 등을 고려하여야 한다.



SW개발보안 국내기준

01 소프트웨어 개발보안 가이드

02 클라우드 서비스(SaaS) 보안인증 가이드

클라우드서비스(SaaS) 보안 인증

SaaS 표준등급 클라우드 보안인증은 중요 데이터를 처리하는 서비스를 대상으로 하며, 13개 분야에서 총 79개의 통제 항목을 준수해야 함. 이 인증 기준은 클라우드 서비스의 보안성과 신뢰성을 확보하기 위한 관리적, 기술적 보호 조치 포함

❗ 소프트웨어 보안과 관련된 통제항목

1. 정보보호 정책 수립 및 운영
2. 서비스 연속성 관리
3. 접근통제
4. 암호화 적용
5. 시스템 개발 및 운영 보안
6. 취약점 관리

클라우드 보안인증 통제항목 [SaaS 표준등급]

[관리적 보호조치]

분야	통제항목	항목수
1.정보보호 정책 및 조직	1.1. 정보보호 정책	3
	1.2. 정보보호 조직	2
2.인적보안	2.1. 내부인력 보안	4
	2.2. 정보보호 교육	1
3.자산관리	3.1. 자산 식별 및 분류	1
	3.2. 자산 변경관리	1
	3.3. 위험관리	1
4.서비스 공급망관리	4.1.공급망 관리정책	2
	4.2. 공급망 변경관리	1
5.침해사고관리	5.1.침해사고대응절차및체계	3
	5.2.침해사고 대응	2
	5.3.사후관리	2
6.서비스 연속성관리	6.1.장애대응	4
	6.2. 서비스 가용성	2
7.준거성	7.1. 법 및 정책 준수	1
	7.2. 정보시스템 감사	2

[기술적 보호조치]

분야	통제항목	항목수
9.가상화 보안	9.1. 가상화 인프라	2
	9.2. 가상 환경	4
10.접근통제	10.1. 접근통제 정책	2
	10.2. 접근권한 관리	3
	10.3. 사용자 식별 및 인증	5
11.네트워크 보안	11.1. 네트워크 보안	5
12.데이터 보호 및 암호화	12.1. 데이터 보호	6
	12.2. 암호화	2
13.시스템 개발 및 도입 보안	13.1. 시스템 분석 및 설계	5
	13.2. 구현 및 시험	4
	13.3. 외주 개발 보안	1

[공공기관용 클라우드컴퓨팅서비스 추가 보호조치]

분야	통제항목	항목수
14.공공기관 보안요구 사항	14.1.관리적 보호조치	4
	14.2.물리적 보호조치	2
	14.3.기술적 보호조치	1

SaaS CSAP 기술적 보호조치

★ ISMS 인증시 점검대체 가능 항목

분야	통제 항목		세부 통제내용	표준	간편
13. 시스템 개발및도입 보안	13.1. 시스템 분석 및 설계	13.1.1. 보안 요구사항 정의★	신규 시스템 개발 및 기존 시스템 변경 시 정보보호 관련 법적 요구사항, 최신 보안취약점, 정보보호 기본요소(기밀성, 무결성, 가용성) 등을 고려하여 보안요구사항을 명확히 정의하고 이를 적용하여야 한다.	0	-
		13.1.2. 인증 및 암호화 기능★	클라우드 시스템 설계 시 사용자 인증에 관한 보안요구사항을 반드시 고려하여야 하며 중요정보의 입·출력 및 송수신 과정에서 무결성, 기밀성이 요구될 경우 법적 요구사항을 고려하여야 한다.	0	0
		13.1.3. 보안로그 기능★	클라우드 시스템 설계 시 사용자의 인증, 권한 변경, 중요정보 이용 및 유출 등에 대한 감사증적을 확보할 수 있도록 하여야 한다.	0	-
		13.1.4. 접근권한 기능★	클라우드 시스템 설계 시 업무의 목적 및 중요도에 따라 접근권한을 부여할 수 있도록 하여야 한다.	0	-
		13.1.5. 시각 동기화★	로그기록의 정확성을 보장하고 법적인 자료로서 효력을 지니기 위해 클라우드 시스템 시각을 공식 표준시각으로 정확하게 동기화 하여야 한다.	0	-

SaaS CSAP 기술적 보호조치

분야	통제 항목		세부 통제내용	표준	간편
13. 시스템 개발및도입 보안	13.2. 구현및시험	13.2.1. 구현 및 시험★	안전한 코딩방법에 따라 클라우드컴퓨팅서비스를 구현하고, 분석/설계 과정에서 도출한 보안요구사항이 정보시스템에 적용되었는지 확인하기 위하여 시험을 수행하여야 한다	0	0
		13.2.2. 개발과 운영환경 분리	개발 및 시험 시스템은 운영시스템에 대한 비인가 접근 및 변경의 위험을 감소하기 위해 원칙적으로 분리하여야 한다. 단 분리하여 운영하기 어려운 경우 그 사유와 타당성을 검토하고 안전성 확보 방안을 마련하여야 한다.	0	-
		13.2.3. 시험 데이터 보안★	시스템 시험 과정에서 운영데이터 유출을 예방하기 위해 시험데이터 생성, 이용 및 관리, 파기, 기술적 보호조치에 관한 절차를 수립하여 이행하여야 한다.	0	-
		13.2.4. 소스 프로그램 보안★	소스 프로그램에 대한 변경관리를 수행하고 인가된 사용자만이 소스 프로그램에 접근할 수 있도록 통제 절차를 수립하여 이행하여야 한다. 또한 소스 프로그램은 운영환경에 보관하지 않는 것을 원칙으로 한다.	0	-
	13.3. 외주개발보안	13.3.1. 외주개발보안★	클라우드 시스템 개발을 외주 위탁하는 경우 분석 및 설계단계에서 구현 및 이관까지의 준수해야 할 보안 요구사항을 계약서에 명시하고 이행여부를 관리·감독 하여야 한다.	0	-



요약 정리

- ✓ 소프트웨어 개발보안을 위한 국내 기준으로 활용되는 소프트웨어 개발보안 가이드에서 설명하고 있는 설계단계 20개의 보안요구사항, 구현단계의 49개 보안약점 제거 기준에 대해 학습함.
- ✓ SaaS 애플리케이션을 대상으로 실시되는 클라우드 보안인증 통제항목의 기술적보호 조치 등에서 설명하는 시스템 개발 및 도입 보안의 점검 항목을 학습함.



참고 문헌

- [KISA] 소프트웨어 개발 보안 가이드(2021.12.29)
- [KISA] 소프트웨어 보안약점 진단가이드(2021)
- [KISA] 클라우드서비스(SaaS)_보안인증기분_해설서(2023.3)
- [KISA] 주요정보통신기반시설 기술적 취약점 분석 평가 상세 가이드(2021.03)
- [오픈이지북스] 실무에 바로 적용하는 해킹 방어를 위한 JAVA 시큐어코딩
- [홍릉과학출판사] 소프트웨어 개발 보안 실무 - 시큐어 코딩 원리와 실제
- [secu BOOK] 웹 해킹과 시큐어코딩 탐지/수정 실습가이드
- [에이콘출판사] 보안 위협 모델링 Threat Modeling - 위협 식별과 대응을 위한 소프트웨어 설계
- [책만] 모두를 위한 소프트웨어 보안 설계와 구현 - 취약점 분석부터 위협 모델링과 완화 전략, 보안 패턴, 암호화까지 안전한 소프트웨어의 모든 것
- [위키북스] 웹 애플리케이션 보안 완벽 가이드 - 체계적으로 배우는 안전한 웹 애플리케이션 제작 기법
- [한빛미디어] 웹 애플리케이션 보안 - 정찰, 공격, 방어 세 단계로 배우는 웹 애플리케이션 보안의 모든 것
- [한빛미디어] 웹 해킹 & 보안 완벽 가이드 - 웹 애플리케이션 보안 취약점을 겨냥한 공격과 방어
- OWASP - <https://owasp.org/>
- CVE - <https://cve.mitre.org/>
- CWE - <https://cwe.mitre.org/>
- SEI CERT Coding Standards - <https://wiki.sei.cmu.edu/confluence/display/seccode>

The background is a vibrant blue gradient. It is decorated with various abstract elements: a large solid blue sphere in the upper left, a smaller sphere with diagonal stripes in the upper right, and another striped sphere in the lower left. Several network diagrams, consisting of white dots connected by thin white lines, are scattered across the image. There are also solid blue rectangular bars of different sizes and orientations. The overall aesthetic is modern and technological.

감사합니다.



퀴즈

1. 다음 중 행정안전부 SW개발보안 가이드와 관련 없는 내용은?

- | | |
|---------------------------------|------------------------------|
| 1) 행정, 공공기관 정보시스템 개발자 대상 | 2) SW보안약점 잔존여부 진단 |
| 3) 테스트 단계부터 SW개발 보안을 적용하기 위한 기준 | 4) 진단 범위는 설계 단계 산출물과 소스코드 전체 |

2. 다음 중 클라우드 서비스 보안 인증과 관련하여, 소프트웨어 보안과 관련된 통제 항목이 아닌 것은?

- | | |
|-----------|----------------------|
| 1) 접근통제 | 2) 시스템 개발 및 운영 보안 |
| 3) 취약점 관리 | 4) 개발 조직의 신원 관리 및 통제 |

3. 다음 중 클라우드 서비스 보안 인증을 나타내는 용어는?

- | | |
|---------|---------|
| 1) CSAP | 2) CCSP |
| 3) SaaS | 4) PaaS |



퀴즈 정답

1. 다음 중 행정안전부 SW개발보안 가이드와 관련 없는 내용은?

3) 테스트 단계부터 SW개발 보안을 적용하기 위한 기준

SW개발보안 가이드는 SW개발 단계부터 보안을 적용하기 위한 기준을 제시하고 있습니다.

2. 다음 중 클라우드 서비스 보안 인증과 관련하여, 소프트웨어 보안과 관련된 통제 항목이 아닌 것은?

4) 개발 조직의 신원 관리 및 통제

개발 조직 관리는 소프트웨어 보안과 관련이 없습니다.

3. 다음 중 클라우드 서비스 보안 인증을 나타내는 용어는?

1) CSAP

CSAP는 Cloud Security Assurance Program의 약어입니다.